

MODULE 05 · DOMAIN 2 - SECURITY AND COMPLIANCE

The Shared Responsibility Model

Where the line sits, and why it moves depending on the service.

DOMAIN 2 of 4 EXAM WEIGHT 30% MODULE 5 of 26

AWS is responsible for security **of** the cloud.
You are responsible for security **in** the
cloud.

Of the cloud, or in the cloud?

AWS - SECURITY OF THE CLOUD

The infrastructure itself

- Data centres, power, cooling, physical access
- Hardware and the global network
- The virtualisation and hypervisor layer
- The managed service software AWS runs

CUSTOMER - SECURITY IN THE CLOUD

Everything you put on it

- Your data, and how it is classified
- Identity and access management policies
- Operating system and firewall configuration
- Application code and its vulnerabilities

THE TIEBREAKER

You can never inspect an AWS data centre, and AWS can never read your bucket policy for you. That is the split.

Always AWS, no exceptions

- ◆ **Physical security of data centres.** Guards, badges, cameras, destruction of failed drives.
- ◆ **Hardware maintenance and replacement.** You never touch a server.
- ◆ **The global network infrastructure** connecting Regions and Availability Zones.
- ◆ **The hypervisor and virtualisation layer.** Isolation between customers.
- ◆ **Availability of Regions and Availability Zones** as a service.

ON THE EXAM

If an option describes something you physically could not do from a console, it belongs to AWS.

Always the customer, no exceptions

- ◆ **Your data.** What it is, how sensitive it is, where you allow it to live.
- ◆ **Who can access it.** IAM users, groups, roles and policies are always yours.
- ◆ **Whether encryption is switched on** and which keys are used.
- ◆ **Client-side encryption** and data integrity checks.
- ◆ **Your application code** and any vulnerability in it.

ON THE EXAM

The customer is always responsible for their data. No service, however managed, moves that line.

The line is not fixed. It **moves** depending on which service you chose.

Where the line sits, by service

SERVICE	AWS HANDLES	YOU HANDLE
Amazon EC2	Hypervisor, hardware, facilities	Guest OS patching, firewall, app, data
Amazon RDS	OS and DB engine patching	DB users, network access, encryption, data
AWS Lambda	OS and runtime patching	Function code, IAM permissions, data
Amazon S3	Durability and storage software	Bucket policies, access settings, data
AWS Fargate	OS and container host patching	Image contents, task IAM role, data

ON THE EXAM

Read down the right-hand column. Data and access appear in every row. Guest OS patching appears in only one.

EC2 or RDS? The patching boundary

AMAZON EC2

You patch the guest OS

- AWS patches the hypervisor beneath it
- You patch the operating system
- You patch the database if you installed one
- You configure the firewall and security groups

AMAZON RDS

AWS patches the OS and engine

- AWS patches the operating system
- AWS patches the database engine
- You still control database users and access
- You still choose whether to encrypt

THE TIEBREAKER

Guest OS patching is the single clearest indicator. On EC2 it is yours. On RDS it is AWS's.

EC2 or Lambda? How far the line moves

AMAZON EC2

You hold the most

- Guest OS, patching, hardening
- Runtime and libraries
- Scaling configuration
- Firewall rules and network config

AWS LAMBDA

You hold the least

- No OS to patch or harden
- AWS patches the language runtime
- AWS handles scaling entirely
- Your code, its permissions, and your data

THE TIEBREAKER

Serverless does not make you responsible for nothing. Your code, your IAM permissions and your data remain yours.

The three shared controls

- ◆ **Patch management.** AWS patches the infrastructure. You patch your guest OS and applications.
- ◆ **Configuration management.** AWS configures its infrastructure devices. You configure your own resources.
- ◆ **Awareness and training.** AWS trains AWS staff. You train your staff.
- ◆ These are the answer when a question asks what is shared, rather than who owns something.
- ◆ Shared does not mean split down the middle. It means both parties do the same category of work, separately.

ON THE EXAM

Shared controls apply to both layers. Each side does that work for the part of the stack it owns.

Encryption, split precisely

- ◆ **AWS provides the capability.** KMS, encryption options on services, TLS endpoints.
- ◆ **You decide to use it.** Enabling encryption at rest is a customer action.
- ◆ That is why encryption at rest is commonly described as a shared responsibility.
- ◆ **Client-side encryption is entirely yours.** AWS cannot do it for you by definition.
- ◆ Key management is yours when you use customer managed keys in KMS.

ON THE EXAM

If an option says AWS encrypts all customer data automatically, treat it with suspicion. You choose.

Sorting exercise

TASK	WHOSE RESPONSIBILITY
Destroying a failed disk drive	AWS
Applying an operating system patch to an EC2 instance	Customer
Applying an operating system patch to an RDS instance	AWS
Configuring an S3 bucket policy	Customer
Ensuring an Availability Zone stays available	AWS
Enabling MFA on the root user	Customer
Classifying which data is sensitive	Customer
Isolating one customer's instance from another's	AWS

ON THE EXAM

Cover the right-hand column and work down it. If you hesitate on the two patching rows, rewatch the EC2 and RDS slide.

How this domain builds distractors

- ◆ **A true statement about the wrong service.** AWS patches the OS is true for RDS, false for EC2.
- ◆ **Something AWS does, offered as a customer duty.** Physical security appears constantly as a distractor.
- ◆ **An absolute.** AWS secures all customer data automatically. Nothing in this model is automatic.
- ◆ **Confusing capability with action.** AWS offers encryption; that is not the same as applying it.
- ◆ When the question names a service, decide the service type first, then answer.

ON THE EXAM

Name the service type before you read the options: infrastructure, managed, or serverless. The answer follows.

A company runs a web application on Amazon EC2 instances behind an Application Load Balancer. A security audit finds that the operating systems on the instances are missing three months of security updates.

The infrastructure manager tells the auditor that patching is handled by AWS as part of the shared responsibility model.

Is the infrastructure manager correct?

- ☐ A Yes. AWS patches all operating systems it hosts
- ☐ B Yes, but only for instances launched from an AWS-provided AMI
- ☐ C No. Guest operating system patching on EC2 is the customer's responsibility
- ☐ D No. Patching is handled by the Application Load Balancer

◆ PAUSE AND DECIDE

Is the infrastructure manager correct?

- A

 Yes. AWS patches all operating systems it hosts
An absolute, and false. AWS patches the OS on managed services like RDS and Lambda, never on EC2.
- B

 Yes, but only for instances launched from an AWS-provided AMI
Plausible-sounding invention. The AMI is patched when published; after launch the instance is entirely yours.
- C

 No. Guest operating system patching on EC2 is the customer's responsibility
EC2 is infrastructure. AWS stops at the hypervisor; everything above it is yours.
- D

 No. Patching is handled by the Application Load Balancer
A load balancer distributes traffic. It has no relationship to instance patching.

THE SIGNAL

EC2 plus operating system patching. That combination has one answer, and it is always the customer.

A company is moving a self-managed PostgreSQL database from EC2 to Amazon RDS. The database administrator asks which of her current duties she will keep afterwards.

Her current duties are: applying OS patches, applying database engine patches, creating database users, deciding whether the storage is encrypted, and replacing failed disks in the data centre.

Which two duties remain hers after moving to Amazon RDS? (Choose two.)

- ☐ A Applying operating system patches
- ☐ B Applying database engine patches
- ☐ C Creating database users
- ☐ D Deciding whether the storage is encrypted
- ☐ E Replacing failed disks

◆ PAUSE AND DECIDE

Which two duties remain hers after moving to Amazon RDS? (Choose two.)

- A

 Applying operating system patches
Handed to AWS by the move. This is the main operational benefit of RDS.
- B

 Applying database engine patches
Also handed to AWS. RDS patches the engine within your chosen maintenance window.
- C

 Creating database users
Access control never transfers. Who can read the data stays yours on every service.
- D

 Deciding whether the storage is encrypted
AWS provides the capability; choosing to enable it is a customer action.
- E

 Replacing failed disks
Never was hers on AWS. Hardware is AWS's on every service, including EC2.

THE SIGNAL

Moving to a managed service hands over the operating system and the engine. It never hands over access or data decisions.

An auditor asks a company to demonstrate the physical access controls protecting the servers that run its AWS workloads, and asks to schedule a visit to the relevant data centre. The company has no ability to arrange such a visit and needs to satisfy the auditor another way.

What should the company do?

- ☐ A Request a data centre visit through AWS Support
- ☐ B Provide AWS compliance reports from AWS Artifact
- ☐ C Run Amazon Inspector against the instances
- ☐ D Enable AWS CloudTrail and supply the logs

◆ PAUSE AND DECIDE

What should the company do?

- A

 Request a data centre visit through AWS Support
Customers do not visit AWS data centres. Physical security is AWS's alone, and inspection is not offered.
- B

 Provide AWS compliance reports from AWS Artifact
Artifact is where AWS publishes its audit reports, such as SOC and ISO. This is how AWS evidences its half.
- C

 Run Amazon Inspector against the instances
Finds software vulnerabilities in your workloads. It says nothing about physical controls.
- D

 Enable AWS CloudTrail and supply the logs
Records API activity in your account. It has no visibility of data centre access.

THE SIGNAL

When an auditor asks about AWS's half of the model, the answer is a report from AWS Artifact.

A company runs three workloads: a legacy application on EC2, an image-processing function on AWS Lambda, and its customer records in Amazon S3.

A new security policy requires that all software vulnerabilities in the operating systems supporting these workloads are patched within seven days.

For which workload does this policy create work for the company?

- | | |
|--|---|
| ☐ A The EC2 application only | ☐ B The Lambda function only |
| ☐ C The EC2 application and the Lambda function | ☐ D All three workloads |

◆ PAUSE AND DECIDE

For which workload does this policy create work for the company?

- A** The EC2 application only
EC2 is the only one of the three where a guest operating system exists that the customer can patch.
- B** The Lambda function only
Backwards. AWS patches the Lambda runtime and its underlying OS entirely.
- C** The EC2 application and the Lambda function
Lambda has no customer-accessible OS. The company could not patch it even if the policy demanded it.
- D** All three workloads
S3 is object storage with no operating system exposed to you at all.

THE SIGNAL

Three services, three positions on the line. Only EC2 leaves a guest operating system in the customer's hands.

What to carry out of this module

- ◆ **AWS secures the cloud. You secure what you put in it.** That is the frame, not the answer.
- ◆ **The line moves by service.** Name the service type first: infrastructure, managed, or serverless.
- ◆ Your data and who can access it are yours on every service, without exception.
- ◆ Guest OS patching is yours on EC2 and AWS's on RDS, Lambda and Fargate. That one row decides many questions.
- ◆ Physical security is never yours, and no service ever makes it yours.

ON THE EXAM

AWS Artifact is how you evidence AWS's half of the model to an auditor. You cannot inspect it yourself.